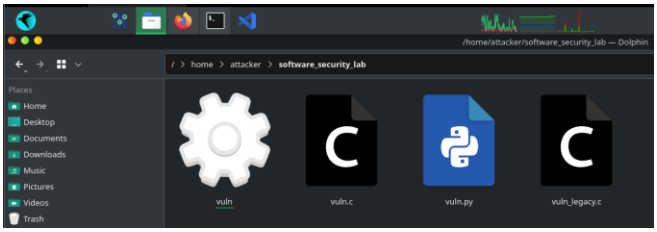


```
┌─[attacker@parrot]─[~/software_security_lab]
└──╼ $bandit vuln.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.5
Run started:2026-03-02 14:27:52.794197

Test results:
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.7.10/blacklists/blacklist_calls.html#b307-eval
   Location: ./vuln.py:8:13
7           # An attacker can provide malicious code instead of a simple math problem.
8           result = eval(user_input)
9
--------------------------------------------------

Code scanned:
        Total lines of code: 7
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 0
        Total issues (by confidence):
                Undefined: 0
```

```
┌─[✗]─[attacker@parrot]─[~/software_security_lab]
└──╼ $gcc -g -fno-stack-protector -o vuln vuln.c
vuln.c: In function ‘main’:
vuln.c:18:5: error: implicit declaration of function ‘gets’; did you mean ‘fgets’? [-Wimplicit-function-declaration]
   18 |     gets(buffer);
      |     ^~~~
      |     fgets
```

```
┌─[✗]─[attacker@parrot]─[~/software_security_lab]
└──╼ $nano vuln_legacy.c
┌─[attacker@parrot]─[~/software_security_lab]
└──╼ $gcc -g -fno-stack-protector -o vuln vuln_legacy.c -Wno-implicit-function-declaration
/usr/bin/ld: /tmp/ccr1JXoN.o: in function `main':
/home/attacker/software_security_lab/vuln_legacy.c:19:(.text+0x73): warning: the `gets' function is dangerous and should
 not be used.
┌─[attacker@parrot]─[~/software_security_lab]
└──╼ $./vuln
Welcome to the vulnerable program!
Please enter your name: Aneesh Sangran

Hello, Aneesh Sangran
```

```
┌─[attacker@parrot]─[~/software_security_lab]
└──╼ $python3 vuln.py
Enter a simple math problem to solve (e.g., 2+2): __import__('os').system('ls -l')
total 32
-rwxrwxr-x 1 attacker attacker 17552 Mar  2 09:36 vuln
-rw-rw-r-- 1 attacker attacker   644 Mar  2 09:30 vuln.c
-rw-rw-r-- 1 attacker attacker   666 Mar  2 09:36 vuln_legacy.c
-rw-rw-r-- 1 attacker attacker   379 Mar  2 09:27 vuln.py
The result is: 0
```